



SolarWinds / SUNBURST

Case Study — December 2020

A nation-state supply chain operation that compromised 18,000 organisations globally, remained undetected for nine months, and reshaped the foundations of enterprise and government cybersecurity doctrine.

APT29 / COZY BEAR

SVR — RUSSIAN FOREIGN INTELLIGENCE

UNC2452

Background & Scope

In December 2020, **FireEye disclosed it had been breached**. Investigation of that breach uncovered the root cause: a backdoored update to **SolarWinds Orion**, a widely-deployed IT infrastructure monitoring platform used across enterprise and government environments worldwide.

The backdoor — designated **SUNBURST** — was distributed through legitimate SolarWinds update infrastructure between **March and June 2020**, pushed to approximately **18,000 customer organisations**. The threat actor was the **Russian Foreign Intelligence Service (SVR)**, operating under the designations APT29 and Cozy Bear.

Key Designations

- **SUNBURST** — the primary backdoor in the Orion binary
- **TEARDROP** — second-stage memory-only implant
- **UNC2452** — Mandiant campaign designation
- **avsvmcloud.com** — primary C2 domain
- **Golden SAML** — cloud persistence technique



Confirmed Victims

Out of 18,000 organisations receiving the backdoored update, approximately **100 high-value targets** were selectively activated for follow-on intrusion activity.

US Federal Government

Treasury, Commerce, DHS, State, Energy, Justice, NIH, DoD, National Nuclear Security Administration

Technology Sector

Microsoft, FireEye, Cisco, Mimecast, Malwarebytes — and SolarWinds itself

Sub-national & Allied Nations

Multiple US state government agencies; undisclosed organisations in Australia, New Zealand, the UK, and Canada

Scale of Damage

The financial and strategic damage from SUNBURST was unprecedented in scope. Remediation efforts spanned multiple years and triggered sweeping legislative and executive reform across the US federal government.

\$100B+

Global Remediation Costs

Total estimated cost across all affected organisations worldwide

\$1B+

Microsoft Alone

Remediation costs declared by Microsoft following investigation of their own compromise

18,000

Organisations Backdoored

Customer organisations that received and installed the trojanised Orion update

9 mo

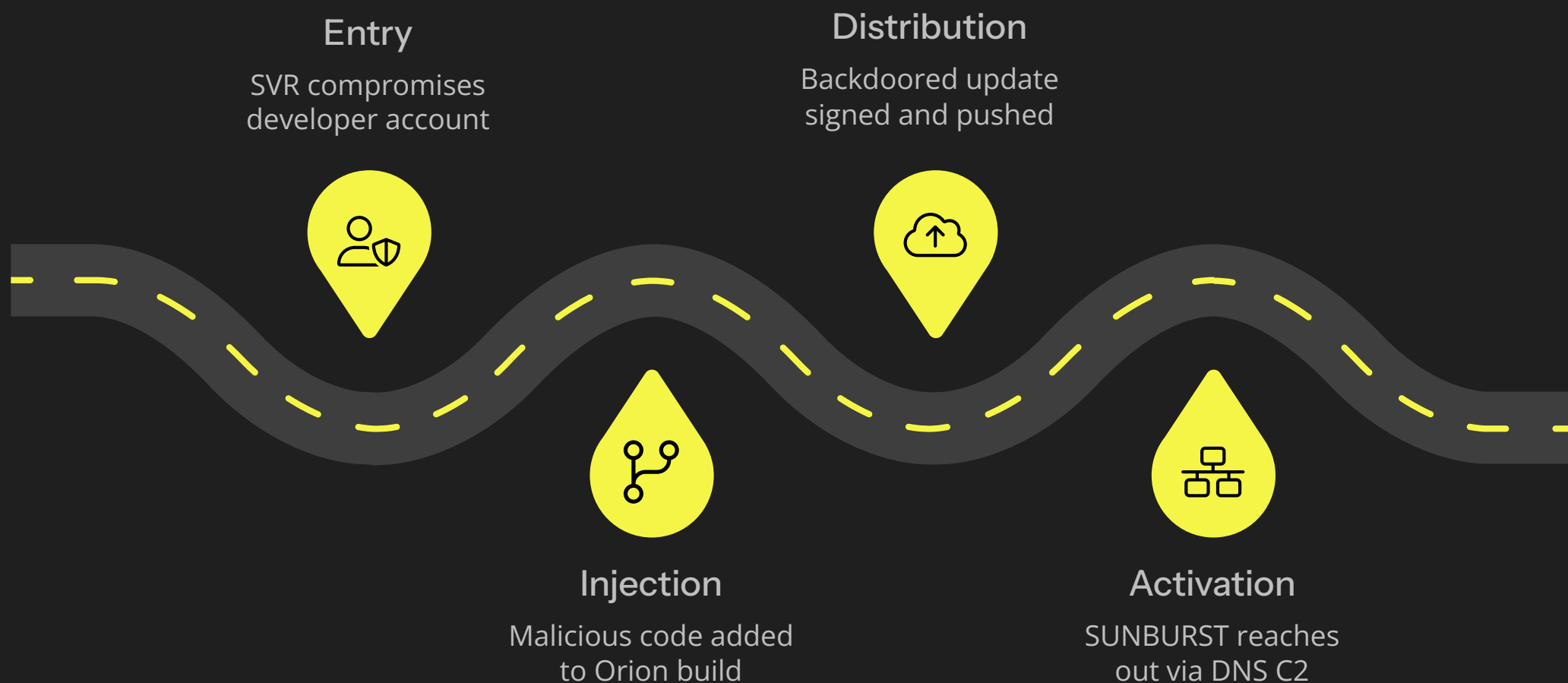
Dwell Time

Months the campaign operated undetected across all affected environments globally

① The US government response included **Executive Order 14028 on Improving the Nation's Cybersecurity** (May 2021), which accelerated mandatory zero-trust adoption across all federal agencies.

Root Cause: A Five-Step Attack Chain

SUNBURST succeeded through a meticulously engineered supply chain intrusion. Each step was designed to exploit trust — in software vendors, update mechanisms, and digitally signed binaries. The following sequence represents one of the most technically sophisticated intrusion chains ever publicly documented.



The chain's power lay in its exploitation of legitimacy: every step involved trusted mechanisms — a signed binary, a standard update channel, a privileged monitoring platform — making detection through conventional controls virtually impossible.

Steps 1–2: Compromising the Build Environment

Step 1 — Initial Access

The SVR gained initial access to SolarWinds' development environment through a **compromised employee account**. From this foothold, the actor moved laterally until reaching the **Orion build system** — the most privileged and consequential target in the entire development pipeline.

The precise method of the initial credential compromise has not been fully disclosed in public reporting, but password-spraying of exposed credentials is assessed as likely.

Step 2 — Build Injection

Malicious code was inserted into **SolarWinds.Orion.Core.BusinessLayer.dll**. Critically, the build modification tool executed *just before compilation*, modified the source, and **reverted it after compilation** — leaving no persistent artefact in source control.

The compiled binary was then signed normally using **legitimate SolarWinds code-signing certificates**, making it indistinguishable from authentic software through standard integrity verification.

⚠ This technique — transient source modification during compilation — is specifically designed to defeat source code audits and version control integrity checks. It represents a direct attack on the software supply chain trust model.

Steps 3–5: Delivery, Activation & Persistence

Step 3 — Distribution via Trusted Channels

The backdoored Orion update was distributed through **normal SolarWinds update infrastructure** between March and June 2020. Customer environments installed the update through standard change management processes. No anomalous signals accompanied delivery — the update appeared, in all respects, to be a legitimate product release.

Step 4 — SUNBURST Activation & C2

Once installed, SUNBURST employed deliberate evasion: it **waited up to two weeks** before first communication; it checked for forensic tooling and self-disabled in certain environments; it used **DNS for C2 communication** — a protocol treated as innocuous by most network defences. Primary C2 was **avsvmcloud.com**.

Step 5 — Lateral Movement & Persistence

For the ~100 activated targets, the actor pivoted from the Orion server — which held broad network access by design — into the wider environment. Persistence was established via **TEARDROP** (memory-only implant) and **Golden SAML attacks** against ADFS, alongside abuse of Azure AD / Entra ID application registrations.

Detection: How the Campaign Was Finally Discovered

Detection came not from automated alerting across any of the 18,000 affected organisations — but from **FireEye's internal incident response discipline**.

During a **routine internal investigation**, a FireEye security analyst noticed that an employee had registered a second MFA device without explanation. The subsequent investigation revealed FireEye's own compromise, which was traced back through Orion to the backdoor. FireEye disclosed publicly and shared indicators of compromise with the community.

Without this accidental discovery, the campaign might have continued for further months — or years. **Not a single SIEM-based alert** detected SUNBURST at any of the affected organisations during the nine-month dwell period.

⊗ **9-month dwell time.** The campaign operated across 100 high-value targets — including classified US government networks — without triggering a single automated detection. This is the canonical case study for detection programme failure.

Failure Map: Lessons for the SOC

SUNBURST is simultaneously a case study in multiple SOC capability failures. Each lesson maps directly to a specific detection or forensics discipline.



Detection Failure (Slide 7)

9-month dwell time. No SIEM-based alert fired at any affected organisation. Detection required an accidental internal IR observation by a victim who happened to be a leading security firm.



Forensics & Signed Binaries (Slides 19–22)

The SUNBURST binary was legitimately signed. Standard integrity checks passed. Post-SolarWinds, **behavioural analysis of trusted binaries** became a mandatory SOC capability rather than an edge case.



Threat Hunting (Slide 13)

The technique that surfaced compromise at most organisations *after* public disclosure. Analysts had to hunt nine months of archived logs to determine selective activation. Hunting became the primary discovery mechanism.



Data Sources: DNS (Slide 26)

DNS query logs were the **most consistent forensic artefact**. Organisations with comprehensive DNS logging could definitively hunt for avsvmcloud.com queries. Those without DNS logging could not determine their exposure status.

Log Retention & Alert Tuning: The Final Lessons

Archiving & Retention (Slides 38)

Many organisations only confirmed compromise when they searched **archived logs against the published IOCs**. Without sufficient retention periods — typically 12+ months — the historical evidence required to determine selective activation simply did not exist. The SolarWinds case made the business case for long-horizon log archiving unanswerable.

- ① Organisations with <90-day retention could not reconstruct their exposure window and were forced to treat themselves as compromised by assumption.

Alert Tuning: The False-Negative Case (Slides 39–40)

Static SIEM signatures did not detect SUNBURST. The actor's TTPs were **entirely novel** — no signature existed at time of deployment. Detection required behavioural analytics, threat hunting, or post-hoc indicator matching. This is the definitive argument against signature-only detection architectures in high-threat environments.

- ⚠ SUNBURST passed every signature-based control across 18,000 deployments for nine consecutive months. Behavioural detection and proactive hunting are not optional augmentations — they are primary controls.

Key Takeaways for Security Practitioners

Supply Chain is a Primary Attack Surface

Trusted vendors, signed updates, and legitimate infrastructure are exploitable. Software supply chain assurance — including build environment integrity and binary behaviour analysis — must be a SOC priority.

DNS Logging is Non-Negotiable

The single most actionable forensic artefact in SUNBURST was DNS. Full DNS query logging with adequate retention is a minimum viable capability for any organisation facing nation-state threats.

Hunting Must Precede Disclosure

Signature-based detection failed universally. Organisations that invested in threat hunting and behavioural analytics were able to determine their exposure status. Those that did not were unable to self-assess without external assistance.

Retention Enables Retrospective Investigation

A nine-month dwell time demands a nine-month-plus retention window. Log archiving is not a cost centre — it is a forensic capability. Absence of historical data means absence of accountability and attribution.